Automated Compliance Assessment Report

Primebrick v3 — Security & Compliance Posture

88.2%

Overall Score

14 compliant · 2 partial · 0 not found · 1 non-compliant

5255 evidence items found across 5 repositories

8 violations detected

Framework Scores

Framework	Controls	Compliant	Partial	Not Found	Non-Compliant	Score
ISO 27001	17	14	2	0	1	88.2%
NIS2	14	11	2	0	1	85.7%
GDPR	10	9	1	0	0	95%
CCPA	6	5	1	0	0	91.7%
OWASP	7	5	1	0	1	78.6%

Control Assessment Details

Role-Based Access Control

COMPLIANT

Fine-grained permission system with role mappings

[CRITICAL]

ISO 27001: A.5.15, A.8.2, A.8.3 · NIS2: Art. 21(2)(b) · GDPR: Art. 5(1)(f), Art. 32 · CCPA: §1798.150(a)(1)

872 evidence items in backend, frontend, microservices

 backend/src/controllers/http/__tests__/collaboration.router.test.ts:9 PERMISSION_DECLARED_TEST: Symbol.for("primebrick.permission_declared"),
 backend/src/controllers/http/__tests__/collaboration.router.test.ts:30 vi.mock("../../../modules/auth/rbac.middleware.js", () => ({
 backend/src/controllers/http/__tests__/collaboration.router.test.ts:31 PERMISSION_DECLARED: mocks.PERMISSION_DECLARED_TEST,

Multi-Factor Authentication

COMPLIANT

MFA enforced at the identity provider (TOTP, hardware keys, passkeys)

[CRITICAL]

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b) · CCPA: §1798.150(a)(1)

1045 evidence items in backend, frontend, sdk

 backend/src/controllers/http/__tests__/role-mappings.router.test.ts:43 vi.mock("../../../modules/auth/mfa-step-up.middleware.js", () => ({
 backend/src/controllers/http/__tests__/role-mappings.router.test.ts:104 it("purge is MFA step-up gated (middleware registered)", () => {
 backend/src/controllers/http/auth/auth-mfa.router.ts:2 * auth-mfa.router — thin controller for MFA / 2FA (TOTP) endpoints.

Audit Trail / Logging

COMPLIANT

Immutable audit log for all CRUD operations

[HIGH]

ISO 27001: A.8.15, A.8.16 · NIS2: Art. 21(2)(b) · GDPR: Art. 30, Art. 33 · CCPA: §1798.130(a)(5)(A)

159 evidence items in backend, dal

 backend/src/controllers/http/__tests__/collaboration.router.test.ts:88 it("GET audit diff service.getAuditLogDiff", async () => {
 backend/src/controllers/http/__tests__/collaboration.router.test.ts:90 audit_log_id: 9,
 backend/src/controllers/http/__tests__/collaboration.router.test.ts:102 expect(body.audit_log_id).toBe(9);

Multi-Tenant Data Isolation

PARTIALLY COMPLIANT

Organization-level data isolation at the DAL layer

[CRITICAL]

ISO 27001: A.8.3 · NIS2: Art. 21(2)(d) · GDPR: Art. 5(1)(c), Art. 32 · CCPA: §1798.150(a)(1)

2 evidence items in backend, dal, sdk

 backend/src/modules/auth/__tests__/boundary-integration.test.ts:52 WHERE key IN ('idp_endpoint', 'idp_client_id', 'idp_client_secret', 'idp_organiz
 sdk/src/auth/session-context.ts:91 * scope — meaning the caller forgot to wrap the code in `runAsSystem()` or

Soft-Delete & Recovery

COMPLIANT

Records are soft-deleted (deleted_at) and can be restored [MEDIUM]

GDPR: Art. 17, Art. 15 · ISO 27001: A.8.10 · NIS2: Art. 21(2)(c)

141 evidence items in backend, dal

 backend/src/controllers/http/__tests__/role-mappings.router.test.ts:3 * the hard-delete-only entity. Verifies the purge contract: soft DELETE
 backend/src/controllers/http/__tests__/role-mappings.router.test.ts:81 it("DELETE /:uuid 404 (no soft-delete route)", async () => {
 backend/src/controllers/http/auth/auth-session.router.ts:59 { key: "deleted_at", label_key: "system.entities.user_profile.fields.deleted_at"

Input Validation

COMPLIANT

Schema-based input validation (Zod, Joi, etc.) [HIGH]

ISO 27001: A.8.28, A.8.25 · NIS2: Art. 21(2)(e) · GDPR: Art. 5(1)(c) · OWASP: A03:2021 — Injection

104 evidence items in backend, microservices, sdk, dal

 backend/src/controllers/http/auth/auth-invitation.router.ts:26 import { z } from "zod";
 backend/src/controllers/http/auth/auth-invitation.router.ts:36 // Zod schemas
 backend/src/controllers/http/auth/auth-mfa.router.ts:15 import { z } from "zod";

Encryption in Transit (TLS/HTTPS)

COMPLIANT

TLS/HTTPS enforced for all API traffic [HIGH]

ISO 27001: A.8.24 · NIS2: Art. 21(2)(g) · GDPR: Art. 32(1)(a) · CCPA: §1798.150(a)(1)

84 evidence items in backend, frontend

 backend/src/controllers/http/auth/auth-session.router.ts:119 // Both auth cookies are httpOnly JS cannot clear them; only the server
 backend/src/controllers/http/mcp/oauth-authorize.router.ts:46 * In production, set `PUBLIC_FE_URL` env var (e.g. https://app.primebrick.com).
 backend/src/controllers/nats-sub/__tests__/service-lifecycle-subscriber.test.ts:44 github_repo_url: "https://github.com/example/svc-a",

Rate Limiting

PARTIALLY COMPLIANT

API rate limiting to prevent abuse and DoS [MEDIUM]

NIS2: Art. 21(2)(c) · ISO 27001: A.8.6 · OWASP: A04:2021 — Insecure Design

2 evidence items in backend, microservices

 backend/src/controllers/http/auth/auth-invitation.router.ts:21 * - IP rate limiting for public endpoints is configured at the infra level
 backend/src/openapi/openapi.ts:561 "429": { description: "Too many login attempts" },

JWT Authentication

COMPLIANT

Short-lived JWT access tokens with refresh token rotation [HIGH]

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b) · OWASP: A07:2021 — Auth Failures

273 evidence items in backend, frontend, sdk, microservices

 backend/src/controllers/http/auth/auth-invitation.router.ts:5 * POST /api/v1/auth/welcome/verify verify invitation token (PUBLIC)
 backend/src/controllers/http/auth/auth-invitation.router.ts:38 const VerifyTokenSchema = z.object({
 backend/src/controllers/http/auth/auth-invitation.router.ts:75 * Verify an invitation token. Returns display_name + expires_at — NEVER email.

OAuth 2.0 / OIDC Identity Provider

COMPLIANT

Delegated authentication via Casdoor/OIDC [HIGH]

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b)

825 evidence items in backend, frontend, sdk

 backend/src/controllers/http/__tests__/role-mappings.router.test.ts:4 * absent (404), DELETE /:uuid/purge wired to the Casdoor-synced service
 backend/src/controllers/http/auth/auth-invitation.router.ts:2 * auth-invitation.router — thin controller for the user onboarding/welcome flow.
 backend/src/controllers/http/auth/auth-invitation.router.ts:105 * Set the user's password in Casdoor + mark invitation COMPLETED.

Parameterized Queries (SQL Injection Prevention)

COMPLIANT

All database queries use parameterized inputs [CRITICAL]

ISO 27001: A.8.28 · OWASP: A03:2021 — Injection · NIS2: Art. 21(2)(e)

141 evidence items in backend, dal

 backend/src/db/audit-query-helper.ts:62 * No raw SQL — fully typed via DAL-pg query DSL.
 backend/src/http/entity-export.ts:15 * - `data` `service.stream(query)` — the SAME filter builder

backend/src/lib/search-keys.ts:8 * `CAST(col AS text)` already applied by the query-builder).

Secrets Management

NON COMPLIANT

No hardcoded secrets; secrets loaded from environment [CRITICAL]

ISO 27001: A.5.17 · NIS2: Art. 21(2)(g) · OWASP: A02:2021 — Cryptographic Failures

228 evidence items in backend, frontend, microservices, sdk, dal · 8 violations

backend/src/controllers/http/mcp/oauth-authorize.router.ts:46 * In production, set `PUBLIC_FE_URL` env var (e.g. https://app.primebrick.com).
backend/src/controllers/http/mcp/oauth-authorize.router.ts:50 if (process.env.PUBLIC_FE_URL) {
backend/src/controllers/http/mcp/oauth-authorize.router.ts:51 return process.env.PUBLIC_FE_URL.replace(/\/$/, "");
backend/src/modules/auth/__tests__/casdoor-api-client.test.ts:16 clientSecret: "test-secret",
backend/src/modules/auth/__tests__/mfa-challenge-token.test.ts:102 const nonHexSecret = "my-ascii-secret-key-that-is-long-enough";
backend/src/modules/auth/__tests__/mfa-integration.test.ts:177 body: { username: ADMIN_USERNAME, password: "wrong-password" },

CORS Configuration

COMPLIANT

Proper CORS configuration to restrict cross-origin access [MEDIUM]

ISO 27001: A.8.23 · OWASP: A05:2021 — Security Misconfiguration

6 evidence items in backend, microservices

backend/src/controllers/http/mcp/oauth-metadata.router.ts:15 import cors from "cors";
backend/src/controllers/http/mcp/oauth-metadata.router.ts:95 // Permissive CORS for discovery endpoints
backend/src/controllers/http/mcp/oauth-metadata.router.ts:96 router.use(cors());

Health Checks & Monitoring

COMPLIANT

Service health endpoints and monitoring [LOW]

NIS2: Art. 21(2)(c) · ISO 27001: A.8.16

413 evidence items in backend, microservices, sdk

backend/src/cache/cache-port-holder.ts:56 * Returns the Redis health status for the `/api/v1/health` endpoint.
backend/src/controllers/http/services-events.router.ts:2 * SSE endpoint for service registry events.
backend/src/controllers/http/services-events.router.ts:10 * - service.heartbeat: microservice heartbeat (status update)

Service Registry & Discovery

COMPLIANT

Microservices register via NATS for dynamic discovery [LOW]

NIS2: Art. 21(2)(d) · ISO 27001: A.5.23

653 evidence items in backend, microservices, sdk

backend/src/controllers/http/collaboration.router.ts:16 * - Subscribe to per-entity bus (refcounted NATS bridge via
backend/src/controllers/http/collaboration.router.ts:72 // 1. Acquire per-entity bus (creates + bridges NATS on first client)
backend/src/controllers/http/services-events.router.ts:2 * SSE endpoint for service registry events.

Structured Error Handling

COMPLIANT

Centralized error handling with proper HTTP status codes [LOW]

ISO 27001: A.8.25 · OWASP: A09:2021 — Security Logging

218 evidence items in backend, microservices, sdk

backend/src/controllers/http/__tests__/harness.ts:4 * Mounts a real Express app + the real `errorHandler`, listens on an
backend/src/controllers/http/__tests__/harness.ts:11 import { errorHandler } from "../../../http/error-handler.js";
backend/src/controllers/http/__tests__/harness.ts:22 app.use(errorHandler);

Data Minimization (Field-Level Access)

COMPLIANT

API responses only include fields the user is authorized to see [MEDIUM]

GDPR: Art. 5(1)(c) · ISO 27001: A.8.3 · CCPA: §1798.100(d)

89 evidence items in backend, dal

backend/src/controllers/http/collaboration.router.ts:8 * - `GET /api/v1/entities/:entity/:uuid/audit/:auditLogId` — field-level diff.
backend/src/controllers/http/collaboration.router.ts:114 // GET /api/v1/entities/:entity/:uuid/audit/:auditLogId — field-level diff
backend/src/db/audit-query-helper.ts:2 import { AuditLogEntity, Project, Filter, Sort, field, buildAuditTrailJoins } fr

Disclaimer

This report is generated by an automated code pattern scanner. It detects the presence of security controls in the source code but does not

constitute a formal compliance certification. Organizations should engage qualified auditors for official certification. The scanner maps code evidence to framework controls based on pattern matching — false positives and false negatives are possible.